# Secure CRM - Hito 1 - Reconocimiento pasivo

Análisis pasivo de seguridad realizado con OWASP ZAP 2.17.0 sobre Secure CRM, utilizando exclusivamente la instancia local del proyecto. Se analizaron las solicitudes y respuestas HTTP del frontend y la API mediante el WAF ModSecurity en modo DetectionOnly, con el objetivo de identificar configuraciones inseguras y complementar el reconocimiento del Equipo Rojo correspondiente al Hito 1.

## Sites: http://localhost:8080 http://localhost:3000

### Generated on Tue, 3 Nov 2026 23:25:05

### ZAP Version: 2.17.0

**ZAP by Checkmarx**

### Summary of Alerts

| Risk Level | Number of Alerts |
|---|---|
| High | 0 |
| Medium | 2 |
| Low | 4 |
| Informational | 3 |

### Insights

| Level | Reason | Site | Description | Statistic |
|---|---|---|---|---|
| Medium | Exceeded Low | | Percentage of memory used | 88 |
| Info | Informational | http://localhost:3000 | Percentage of responses with status code 2xx | 100 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type application /javascript | 33 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type font /woff2 | 8 % |
| | | | Percentage of endpoints | |

| | | | | |
|---|---|---|---|---|
| Info | Informational | http://localhost:3000 | with content type image /png | 5 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type image /svg+xml | 2 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type text /css | 2 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type text /html | 2 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with content type text/x-component | 44 % |
| Info | Informational | http://localhost:3000 | Percentage of endpoints with method GET | 100 % |
| Info | Informational | http://localhost:3000 | Count of total endpoints | 36 |
| Info | Informational | http://localhost:8080 | Percentage of responses with status code 2xx | 100 % |
| Info | Informational | http://localhost:8080 | Percentage of endpoints with content type application /json | 40 % |
| Info | Informational | http://localhost:8080 | Percentage of endpoints with method GET | 30 % |
| | | | Percentage of | |

| | | | | |
|---|---|---|---|---|
| Info | Informational | http://localhost:8080 | endpoints with method OPTIONS | 60 % |
| Info | Informational | http://localhost:8080 | Percentage of endpoints with method POST | 10 % |
| Info | Informational | http://localhost:8080 | Count of total endpoints | 10 |
| Info | Informational | https://clientservices.googleapis.com | Percentage of responses with status code 2xx | 100 % |
| Info | Informational | https://clientservices.googleapis.com | Percentage of endpoints with content type text/plain | 100 % |
| Info | Informational | https://clientservices.googleapis.com | Percentage of endpoints with method POST | 100 % |
| Info | Informational | https://clientservices.googleapis.com | Count of total endpoints | 1 |
| Info | Informational | https://clientservices.googleapis.com | Percentage of slow responses | 100 % |
| Info | Informational | https://content-autofill.googleapis.com | Percentage of responses with status code 2xx | 100 % |
| Info | Informational | https://content-autofill.googleapis.com | Percentage of endpoints with content type text/plain | 100 % |
| Info | Informational | https://content-autofill.googleapis.com | Percentage of endpoints with method GET | 100 % |
| Info | Informational | https://content-autofill.googleapis.com | Count of total endpoints | 3 |
| Info | Informational | https://content-autofill.googleapis.com | Percentage of slow responses | 100 % |

| | | | | |
|---|---|---|---|---|
| Info | Informational | https://passwordsleakcheck-pa.googleapis.com | Percentage of responses with status code 4xx | 100 % |
| Info | Informational | https://passwordsleakcheck-pa.googleapis.com | Percentage of endpoints with content type application /x-protobuf | 100 % |
| Info | Informational | https://passwordsleakcheck-pa.googleapis.com | Percentage of endpoints with method POST | 100 % |
| Info | Informational | https://passwordsleakcheck-pa.googleapis.com | Count of total endpoints | 1 |
| Info | Informational | https://passwordsleakcheck-pa.googleapis.com | Percentage of slow responses | 100 % |

## Alerts

| Name | Risk Level | Number of Instances |
|---|---|---|
| Content Security Policy (CSP) Header Not Set | Medium | 1 |
| Missing Anti-clickjacking Header | Medium | 1 |
| Cookie No HttpOnly Flag | Low | 1 |
| Cookie without SameSite Attribute | Low | 1 |
| Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s) | Low | Systemic |
| X-Content-Type-Options Header Missing | Low | Systemic |
| Authentication Request Identified | Informational | 1 |
| Modern Web Application | Informational | 1 |
| Session Management Response Identified | Informational | 1 |

## Alert Detail

| Medium | Content Security Policy (CSP) Header Not Set |
|---|---|
| Description | Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files. |
| URL | http://localhost:3000/ |
| Node Name | http://localhost:3000/ |

| | |
|---|---|
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | |
| Instances | 1 |
| Solution | Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header. |
| Reference | https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP<br>https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html<br><br>https://www.w3.org/TR/CSP/<br>https://w3c.github.io/webappsec-csp/<br>https://web.dev/articles/csp<br>https://caniuse.com/#feat=contentsecuritypolicy<br>https://content-security-policy.com/ |
| CWE Id | 693 |
| WASC Id | 15 |
| Plugin Id | 10038 |

| **Medium** | **Missing Anti-clickjacking Header** |
|---|---|
| Description | The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options. |
| URL | http://localhost:3000/ |
| Node Name | http://localhost:3000/ |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | |
| Instances | 1 |
| Solution | Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app.<br><br>If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive. |
| Reference | https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options |
| CWE Id | 1021 |
| WASC Id | 15 |
| Plugin Id | 10020 |

| **Low** | **Cookie No HttpOnly Flag** |
|---|---|
| Description | A cookie has been set without the HttpOnly flag, which means that the cookie can be accessed by JavaScript. If a malicious script can be run on this page then the cookie will be accessible and can be transmitted to another site. If this is a session cookie then session hijacking may be possible. |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |

| | |
|---|---|
| Method | POST |
| Attack | |
| Evidence | Set-Cookie: session |
| Other Info | |
| Instances | 1 |
| Solution | Ensure that the HttpOnly flag is set for all cookies. |
| Reference | https://owasp.org/www-community/HttpOnly |
| CWE Id | 1004 |
| WASC Id | 13 |
| Plugin Id | 10010 |

| **Low** | **Cookie without SameSite Attribute** |
|---|---|
| Description | A cookie has been set without the SameSite attribute, which means that the cookie can be sent as a result of a 'cross-site' request. The SameSite attribute is an effective counter measure to cross-site request forgery, cross-site script inclusion, and timing attacks. |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |
| Method | POST |
| Attack | |
| Evidence | Set-Cookie: session |
| Other Info | |
| Instances | 1 |
| Solution | Ensure that the SameSite attribute is set to either 'lax' or ideally 'strict' for all cookies. |
| Reference | https://datatracker.ietf.org/doc/html/draft-ietf-httpbis-cookie-same-site |
| CWE Id | 1275 |
| WASC Id | 13 |
| Plugin Id | 10054 |

| **Low** | **Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)** |
|---|---|
| Description | The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to. |
| URL | http://localhost:3000/ |
| Node Name | http://localhost:3000/ |
| Method | GET |
| Attack | |
| Evidence | X-Powered-By: Next.js |
| Other Info | |
| URL | http://localhost:8080/api/dashboard |
| Node Name | http://localhost:8080/api/dashboard |

| | |
|---|---|
| Method | GET |
| Attack | |
| Evidence | X-Powered-By: Express |
| Other Info | |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login |
| Method | OPTIONS |
| Attack | |
| Evidence | X-Powered-By: Express |
| Other Info | |
| URL | http://localhost:8080/api/dashboard |
| Node Name | http://localhost:8080/api/dashboard |
| Method | OPTIONS |
| Attack | |
| Evidence | X-Powered-By: Express |
| Other Info | |
| URL | http://localhost:8080/api/tickets |
| Node Name | http://localhost:8080/api/tickets |
| Method | OPTIONS |
| Attack | |
| Evidence | X-Powered-By: Express |
| Other Info | |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |
| Method | POST |
| Attack | |
| Evidence | X-Powered-By: Express |
| Other Info | |
| Instances | Systemic |
| Solution | Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers. |
| Reference | https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework<br>https://www.troyhunt.com/shhh-dont-let-your-response-headers/ |
| CWE Id | 497 |
| WASC Id | 13 |
| Plugin Id | 10037 |

| Low | X-Content-Type-Options Header Missing |
| --- | --- |
| Description | The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing. |
| URL | http://localhost:3000/_next/static/chunks/webpack-37d323df850f6e7b.js |
| Node Name | http://localhost:3000/_next/static/chunks/webpack-37d323df850f6e7b.js |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:3000/_next/static/css/6d9ecba392c365a4.css |
| Node Name | http://localhost:3000/_next/static/css/6d9ecba392c365a4.css |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:3000/_next/static/media/9d5a263311222317-s.p.woff2 |
| Node Name | http://localhost:3000/_next/static/media/9d5a263311222317-s.p.woff2 |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:3000/_next/static/media/bb3ef058b751a6ad-s.p.woff2 |
| Node Name | http://localhost:3000/_next/static/media/bb3ef058b751a6ad-s.p.woff2 |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. |

| | |
|---|---|
| | At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:3000/_next/static/media/e4af272ccee01ff0-s.p.woff2 |
| Node Name | http://localhost:3000/_next/static/media/e4af272ccee01ff0-s.p.woff2 |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:8080/api/dashboard |
| Node Name | http://localhost:8080/api/dashboard |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:8080/api/tickets |
| Node Name | http://localhost:8080/api/tickets |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:8080/api/users |
| Node Name | http://localhost:8080/api/users |
| Method | GET |
| Attack | |
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |
| Method | POST |
| Attack | |

| | |
|---|---|
| Evidence | |
| Other Info | This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.<br><br>At "High" threshold this scan rule will not alert on client or server error responses. |
| Instances | Systemic |
| Solution | Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages.<br><br>If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing. |
| Reference | https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85)<br>https://owasp.org/www-community/Security_Headers |
| CWE Id | 693 |
| WASC Id | 15 |
| Plugin Id | 10021 |

| **Informational** | **Authentication Request Identified** |
|---|---|
| Description | The given request has been identified as an authentication request. The 'Other Info' field contains a set of key=value lines which identify any relevant fields. If the request is in a context which has an Authentication Method set to "Auto-Detect" then this rule will change the authentication to match the request identified. |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |
| Method | POST |
| Attack | |
| Evidence | password |
| Other Info | userParam=username<br><br>userValue=admin<br><br>passwordParam=password<br><br>referer=http://localhost:3000/ |
| Instances | 1 |
| Solution | This is an informational alert rather than a vulnerability and so there is nothing to fix. |
| Reference | https://www.zaproxy.org/docs/desktop/addons/authentication-helper/auth-req-id/ |
| CWE Id | |
| WASC Id | |
| Plugin Id | 10111 |

| **Informational** | **Modern Web Application** |
|---|---|
| Description | The application appears to be a modern web application. If you need to explore it automatically then the Client Spider may well be more effective than the standard one. |
| URL | http://localhost:3000/ |
| Node Name | http://localhost:3000/ |
| Method | GET |
| | |

| | |
|---|---|
| Attack | |
| Evidence | <script src="/_next/static/chunks/b4553ad9-9a23718262c94160.js" async=""></script> |
| Other Info | No links have been found while there are scripts, which is an indication that this is a modern web application. |
| Instances | 1 |
| Solution | This is an informational alert and so no changes are required. |
| Reference | |
| CWE Id | |
| WASC Id | |
| Plugin Id | 10109 |

| **Informational** | **Session Management Response Identified** |
|---|---|
| Description | The given response has been identified as containing a session management token. The 'Other Info' field contains a set of header tokens that can be used in the Header Based Session Management Method. If the request is in a context which has a Session Management Method set to "Auto-Detect" then this rule will change the session management to use the tokens identified. |
| URL | http://localhost:8080/api/auth/login |
| Node Name | http://localhost:8080/api/auth/login ()({username,password}) |
| Method | POST |
| Attack | |
| Evidence | token |
| Other Info | json:token<br><br>cookie:session |
| Instances | 1 |
| Solution | This is an informational alert rather than a vulnerability and so there is nothing to fix. |
| Reference | https://www.zaproxy.org/docs/desktop/addons/authentication-helper/session-mgmt-id/ |
| CWE Id | |
| WASC Id | |
| Plugin Id | 10112 |